LEXIGRID

Comprehensive User Operations Guide

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

LexiGrid Comprehensive User Operations Guide **5**

1. Sign in and select an organization . . . 5
2. Dashboard and portfolio interpretation . . . 5
3. Create and assign a risk . . . 5
4. Assess risk manually . . . 6
5. Automatic AI assessment and manual reassessment . . . 6
6. AI Evidence Workspace: inspect assessment inputs . . . 7
7. AI Evidence Workspace: link controls and upload evidence . . . 7
8. Answer AI missing-information questions . . . 7
9. Treat, resolve, and close a risk . . . 8
10. Controls . . . 8
11. Policies . . . 9
12. Frameworks and requirements . . . 9
13. Approvals . . . 9
14. Remediations . . . 10
15. Vendors . . . 10
16. Business Services . . . 10
17. Loss Events . . . 11
18. Audit and activity history . . . 11
19. Security and authenticator enrollment . . . 11
20. Administration and organization names . . . 12
21. Reports and risk attribution . . . 12
22. Exports and data handling . . . 13
23. Enterprise IRM . . . 13
24. Workflows . . . 13
25. Bulk Import: choose the right template . . . 14
26. Bulk Import: controls CSV worked example . . . 14
27. Bulk Import: policies CSV worked example . . . 15
28. Bulk Import: frameworks and requirements . . . 15
29. Bulk Import: validation, limits, and recovery . . . 15
30. Troubleshooting and support evidence . . . 16
31. Entra ID and AD FS sign-in . . . 16
32. Required MFA enrollment and recovery . . . 16
33. Reviewed PDF and DOCX extraction . . . 17
34. Failed notification recovery . . . 17
35. Evidence download errors . . . 17

Import requirements when no framework exists . . . 17
Exact CSV formats shown on the import screen . . . 17
Review and explicitly apply an AI assessment . . . 18

Editing records in LexiGrid 5.54.15 **20**

Risk example . . . 20
Control example . . . 21
Framework example . . . 21
Policy example . . . 21
Enterprise IRM example . . . 21
Security and operational notes . . . 21

Reviewed document import **22**

What to review . . . 22
Select all and complete the import . . . 22
Import behavior . . . 23
Scope and limitations . . . 23
ISO/IEC 27001:2022 PDFs . . . 23
Import requirements when no framework exists . . . 24
Large PDF documents and page ranges . . . 24
NIST SP 800-53 Revision 5 catalogue extraction . . . 24
PDF layout padding and extraction diagnostics . . . 25
Choose the record type and verify the destination . . . 25
Default accountable owner and duplicate control imports . . . 26
CJIS Security Policy version 6.1 . . . 26
Requirements navigation . . . 26

Risk assessment methodologies and reports **26**

Perform a single-risk or batch assessment . . . 26
Available methodology profiles . . . 28
FAIR quantitative assumptions and output . . . 28
Export contents and interpretation . . . 29
Official references . . . 29
Deployment and runtime behavior . . . 29

Automatic risk-to-governance matching **29**

Open a risk to scan . . . 29
Coverage and interpretation . . . 30
Model configuration and data . . . 30

API . . . 30

Compliance audits: applicability, implementation and effectiveness 31

What the audit does . . . 31

1. Create the complete scope snapshot . . . 31

2. Collect supporting evidence . . . 32

3. Test and review every safeguard . . . 32

4. Independent final review . . . 33

5. Reports and provenance . . . 33

API reference . . . 33

Control-owner independence . . . 34

Risk change history and independent remediation closure 34

View risk changes . . . 34

Close a remediation with an independent review . . . 34

Risk acceptance, expiry and independent approvals 35

Request bounded risk acceptance . . . 35

Independently decide or revoke . . . 36

Expiry and re-review . . . 36

Edit, close and AI assessment . . . 36

Native approvals and generic workflows . . . 37

Audit control-owner independence . . . 37

API . . . 37

LexiGrid Comprehensive User Operations Guide

Shahryar Jahangir, Aniza Inc.

This guide documents the major interface functions with procedures, examples, expected results and cautions. PDF: `docs/distribution/LexiGrid_User_Guide.pdf`.

1. Sign in and select an organization

Authenticate to the correct tenant and establish a session.

Step-by-step

1. Open the LexiGrid web interface and select the organization name from the tenant dropdown.

2. Enter your account credentials and sign in.

3. Verify the displayed organization before creating or changing records.

4. Use Logout when finished, especially on shared workstations.

Example: Example: Select "Aniza Inc." rather than typing its internal tenant UUID. A user with access to more than one tenant must select the intended organization.

Verification: Expected: The dashboard loads for the selected tenant. Confirm that the risk list belongs to that organization.

Cautions: Tenant names may be visible before authentication. Never assume that a displayed tenant implies authorization. If authentication fails, contact the tenant administrator.

2. Dashboard and portfolio interpretation

Review risk exposure and prioritize work.

Step-by-step

1. Open Dashboard after signing in.

2. Inspect counts and risk severity summaries.

3. Compare the dashboard with the Reports workspace when investigating a discrepancy.

4. Open the underlying risk records before making management decisions.

Example: Example: A spike in high-rated risks may reflect new registrations, reassessments, or changes in the scoring distribution; inspect the underlying records.

Verification: Expected: Portfolio indicators represent the active tenant and can be reconciled to risk records.

Cautions: A dashboard metric is not evidence that controls are effective. Check the underlying assessment and audit trail.

3. Create and assign a risk

Document a clear cause-event-consequence risk statement.

Step-by-step

1. Navigate to Risks and select the create action.

2. Enter a concise title and a description identifying threat/cause, event, affected asset or process, and business consequence.

3. Choose category and accountable owner.

4. Set likelihood and impact using the organization-approved 1-5 methodology.

5. Save, then reopen the record to verify persistence.

Example: Example: "Standing privileged access to production databases may permit unauthorized modification of financial records, causing regulatory and operational impact." Assign the Infrastructure Security owner.

Verification: Expected: The risk appears in the Risks list and its calculated score reflects likelihood x impact.

Cautions: Avoid generic descriptions such as "password risk." Do not include passwords, API keys, or secrets in risk descriptions.

4. Assess risk manually

Record a human-owned risk judgment.

Step-by-step

1. Open Risks and select the relevant risk.

2. Review the description, owner, business context, and known controls.

3. Set likelihood and impact based on evidence and the approved risk methodology.

4. Document the rationale and any treatments in the relevant record fields/workspaces.

5. Save and verify the score and modification attribution.

Example: Example: Likelihood 3 and impact 4 produces a score of 12. Record why the event is possible and why its business impact is major.

Verification: Expected: The official score changes only through authorized risk-management actions, not through AI recommendations.

Cautions: Inherent, residual, and target scores must not be treated as interchangeable; use the organization's definitions consistently.

5. Automatic AI assessment and manual reassessment

Use model-generated recommendations without surrendering risk ownership.

Step-by-step

1. Open Risks, select an active risk, and choose Manage.

2. For authorized roles, automatic AI evaluation may start when the risk is opened. Wait for the proposed assessment or a provider error.

3. Review current versus proposed likelihood, impact, score, rationale, and suggested actions.

4. Inspect confidence and evidence gaps before accepting the analysis as useful.

5. Choose Evaluate with AI to request a fresh assessment after changing evidence context.

6. Choose Keep current assessment, or Apply AI assessment and confirm the exact checked score change.

Example: Example: An application using local passwords has an official score of 16. The AI may propose a different rating if linked control tests establish enforced MFA, strong hashing, and restricted network access. An unchanged rating is not automatically an error.

Verification: Expected: An AI recommendation is stored as a proposal. The authoritative risk rating remains unchanged unless an authorized user explicitly applies the reviewed proposal or makes a manual risk edit.

Cautions: AI outputs may be incomplete or wrong. A local Ollama model and cloud providers require correct configuration. Never interpret "confidence" as a calibrated statistical probability.

6. AI Evidence Workspace: inspect assessment inputs

Understand precisely which evidence the model considered.

Step-by-step

1. Open Risks -> Manage -> AI Evidence Workspace.
2. Review linked controls and their testing results.
3. Inspect associated findings and evidence metadata.
4. Review previous assessments and treatments where available.
5. Read the evidence gaps and identify which facts require confirmation.

Example: Example: For an authentication risk, look for a linked MFA control, recent control test, failed access-review finding, and evidence attachment metadata.

Verification: Expected: You can identify which records informed the assessment and which information was missing.

Cautions: An evidence filename or hash is not proof that the AI read its contents. Uploaded documents are not automatically interpreted by the model in this release.

7. AI Evidence Workspace: link controls and upload evidence

Improve risk context using existing governance records.

Step-by-step

1. Create or locate the relevant control in Controls.
2. Open the risk's AI Evidence Workspace.
3. Select the link-control action and associate the control with the risk.
4. Choose the linked control and upload supporting evidence using the workspace.
5. Confirm the attachment appears and inspect its metadata.
6. Re-run Evaluate with AI to incorporate the new context.

Example: Example: Link IAM-001 "MFA for privileged access," then attach the quarterly MFA enforcement test report. The model receives the evidence metadata and linked structured results.

Verification: Expected: Linked controls, test results, findings, and evidence metadata appear in the assessment context.

Cautions: Upload only authorized documents. Avoid secrets and personal information. Linking unrelated controls can distort the assessment.

8. Answer AI missing-information questions

Record relevant attestations transparently.

Step-by-step

1. Open the AI Evidence Workspace and inspect missing-information prompts.

2. Enter a factual answer with date, scope, and source where known.

3. Save the answer and verify that it is associated with the risk.

4. Attach or link independent corroboration when available.

5. Re-run AI assessment and review whether the identified gap is resolved.

Example: Example: Question: "Is MFA enforced?" Answer: "Yes, through the enterprise access gateway for production administrative users; tested 2026-10-15 by IAM Operations."

Verification: Expected: The saved answer becomes available to the next assessment and retains user attribution.

Cautions: A user-entered answer is an unverified attestation until corroborated; do not represent it as independently verified evidence.

9. Treat, resolve, and close a risk

Close risks with an auditable disposition rather than deleting history.

Step-by-step

1. Open Risks and select the target record.

2. Use Manage to review status and existing treatment.

3. Confirm the risk meets your organization's closure criteria and that required approvals are complete.

4. Choose Resolve & Close, enter a specific resolution justification, and submit.

5. Verify closed status, closed-by attribution, and inclusion in reports.

Example: Example: "The legacy local-authentication service was retired on 2026-10-20; production access was migrated to enterprise SSO and independently verified."

Verification: Expected: The record is closed, not deleted; its history remains reportable.

Cautions: Closure and formal approval are separate concepts. Do not close a risk merely because the AI suggested mitigation.

10. Controls

Maintain preventive, detective, and corrective control records.

Step-by-step

1. Navigate to Controls.

2. Create a control with a unique code, clear title, description, accountable owner, and status.

3. Use planned, implemented, or retired as appropriate.

4. Save and verify the record.

5. Link the control to risks through the AI Evidence Workspace when relevant.

Example: Example: IAM-001, "Privileged MFA," description "Require MFA for privileged production access," owner "IAM Team," status "implemented."

Verification: Expected: The control is available in the tenant and can be linked to a risk.

Cautions: Implemented does not necessarily mean effective; test results and evidence are needed to establish operating effectiveness.

11. Policies

Maintain policy records and distinguish draft from approved material.

Step-by-step

1. Navigate to Policies.

2. Create a unique policy code and title.

3. Enter policy body and owner; use clear mandatory language for mandatory requirements.

4. Save the draft and route it through the organization's approval process where applicable.

5. Review the policy record and approval evidence before treating it as effective.

Example: Example: POL-001 "Access Control Policy" states that privileged access must be approved, time-bounded, and reviewed.

Verification: Expected: New imported policies begin as draft; creation alone does not imply approval.

Cautions: Bulk import is structured policy text import, not extraction from an uploaded PDF or DOCX.

12. Frameworks and requirements

Catalog regulatory and industry frameworks without fabricating source text.

Step-by-step

1. Navigate to Frameworks and register the framework name and revision.

2. Use Bulk Import for a large requirements catalog.

3. Import the framework before its requirements.

4. Verify framework name/revision and requirement references after import.

Example: Example: Register "NIST CSF", revision "2.0", then import approved requirement/reference text from an authorized source.

Verification: Expected: Framework records and requirements are associated with the selected tenant.

Cautions: Confirm licensing and accuracy of standards text. Example template rows are not authoritative quotations.

13. Approvals

Track human authorization of risk and governance decisions.

Step-by-step

1. Open Approvals.

2. Locate pending approval items and inspect the subject and supporting justification.

3. Confirm your authority and any conflict-of-interest rules.

4. Record approval or rejection with a decision rationale.

5. Return to the originating risk or enterprise record and verify the outcome.

Example: Example: The risk owner requests acceptance of residual privileged-access exposure; an authorized approver reviews control test evidence and records a decision.

Verification: Expected: Approval status, approver identity, and decision time are available in history and applicable reports.

Cautions: A risk marked closed is not necessarily approved. Never approve your own request if segregation of duties prohibits it.

14. Remediations

Track corrective actions through completion.

Step-by-step

1. Open Remediations and create an action associated with the relevant issue or risk when supported.

2. Specify a concrete deliverable, accountable owner, and target date.

3. Update progress and attach verification evidence using available record functions.

4. Submit the action as ready_for_review. An independent tester must record a subsequent passing test on the finding's control and upload its supporting files. An independent authorized reviewer then selects closed, chooses the retest and 1-5 files, and records a review attestation. The creator or recorded lifecycle participants cannot approve closure. See the Risk Change History and Independent Remediation Closure procedures for details.

Example: Example: "Remove standing production database admin access; implement just-in-time elevation by 2026-12-15."

Verification: Expected: Remediation progress is separately traceable from the risk rating.

Cautions: Completion claims must be supported by evidence; creating a remediation does not automatically reduce risk.

15. Vendors

Document third-party exposure and accountability.

Step-by-step

1. Open Vendors and register the supplier.

2. Record business relationship and criticality using available fields.

3. Identify associated services and known risks in relevant workspaces.

4. Review periodically and update material changes.

Example: Example: A cloud payroll processor is marked business-critical because payroll availability and employee data are affected.

Verification: Expected: The vendor is searchable in the tenant's register.

Cautions: Vendor registration is not a completed due-diligence assessment; independently evaluate contractual and security evidence.

16. Business Services

Record business-service importance and recovery expectations.

Step-by-step

1. Open Business Services and register a service.

2. Identify accountable owner and criticality.

3. Record recovery time objective (RTO) and recovery point objective (RPO) where supported.

4. Validate the targets with business stakeholders.

Example: Example: Online Banking has RTO 4 hours and RPO 15 minutes as approved business requirements.

Verification: Expected: Service criticality and recovery requirements are available for risk analysis.

Cautions: RTO/RPO values are requirements, not evidence that recovery capabilities have been tested.

17. Loss Events

Capture realized operational impact.

Step-by-step

1. Open Loss Events and create an event for an actual incident or realized loss.

2. Record date, description, affected process, and quantified impact where available.

3. Associate with risk context when supported by the interface.

4. Preserve source evidence and update the record when the loss is finalized.

Example: Example: A payment-processing outage caused four hours of downtime and verified customer reimbursement expense.

Verification: Expected: The loss event remains available for operational-risk trend analysis.

Cautions: Separate estimated exposure from confirmed financial loss; do not disclose unnecessary personal information.

18. Audit and activity history

Investigate who performed changes and when.

Step-by-step

1. Open Audit and filter or locate relevant records.

2. Identify actor, action, affected object, outcome, and timestamp.

3. Compare with the risk report's Created by, Updated by, Approved by, and Closed by columns.

4. Escalate suspicious or missing entries to the security administrator.

Example: Example: A risk's score changed from 12 to 16; inspect audit history to identify the modifying account and time.

Verification: Expected: Recorded operations can be traced to users where the underlying audit event exists.

Cautions: Older records may have incomplete attribution; blank fields are preferable to invented users.

19. Security and authenticator enrollment

Protect the account using supported security controls.

Step-by-step

1. Sign in with your password; authenticator enrollment is optional unless your organization explicitly requires it. Open Security and select Add authenticator whenever you are ready.

2. Scan the displayed QR code with an approved authenticator. If scanning is unavailable, expand the manual setup key. The setup key is not the confirmation code. Setup is generated locally without an external QR service.

3. Enter the current six-digit code generated by that authenticator entry and select Enable MFA. Spaces in a pasted code are accepted. Keep phone and server date/time synchronized.

4. Successful confirmation keeps you signed in using a new session and revokes older sessions. Reopening an unfinished setup retains its key. Cancel setup discards only an unfinished setup; closing the dialog lets you finish later. Retain an approved administrator-assisted recovery procedure; this UI does not issue backup recovery codes.

5. Use session-management controls to revoke sessions when necessary.

Example: Example: Enroll a TOTP authenticator for a privileged tenant-administrator account.

Verification: Expected: Enrollment succeeds and a fresh authenticator code is accepted on sign-in.

Cautions: Never send the authenticator secret or recovery codes in support tickets. A 500 error requires server-log investigation; avoid rotating the MFA encryption key casually.

20. Administration and organization names

Manage tenant-facing identity and authorized users.

Step-by-step

1. Open Administration if your role permits.

2. Set a recognizable organization display name.

3. Create or manage users and assign least-privilege roles.

4. Verify the organization name appears in the login dropdown.

5. Review the audit trail after administrative changes.

Example: Example: Rename tenant display name to "Aniza Inc." without changing its internal tenant identifier.

Verification: Expected: Existing tenant-scoped records retain their relationships.

Cautions: The login dropdown exposes tenant display names. Avoid sensitive tenant labels where discovery is a concern.

21. Reports and risk attribution

Generate an auditable view of the full risk portfolio.

Step-by-step

1. Open Reports.

2. Select filters such as status, category, or owner; include closed risks when required.

3. Review current risk rating and attribution columns.

4. Check Created by, Updated by, Approved by, approval status/count, Closed by, and Last updated.

5. Export CSV and open it in a trusted spreadsheet application.

6. Reconcile a sample of records to the Audit and Approvals workspaces.

Example: Example: Produce the quarter-end report of all open and closed cybersecurity risks, including their latest approvers and closure owners.

Verification: Expected: The report covers risks in the authenticated tenant, including those beyond the first page of the UI list.

Cautions: Ordinary reports are tenant-scoped. Platform administrators may explicitly select organizations in the separate Platform risk report panel; each export is audited. Approval attribution depends on recorded approval events. CSV, XLSX and PDF exports are available.

22. Exports and data handling

Distribute information while preserving confidentiality.

Step-by-step

1. Open the appropriate reporting or export function.
2. Select the authorized data scope and format.
3. Export and verify row count and expected fields.
4. Store the output in an approved location with appropriate access controls.
5. Delete local copies when no longer required under policy.

Example: Example: Export a CSV for an internal audit committee and verify closed risks and user-attribution fields are present.

Verification: Expected: Exported records reflect the selected tenant and report filters.

Cautions: CSV files can contain sensitive descriptions; treat them as controlled data. Avoid enabling spreadsheet macros from untrusted sources.

23. Enterprise IRM

Manage governance records beyond the conventional risk register.

Step-by-step

1. Open Enterprise IRM and choose a record type such as Obligation, Control Test, Exception, or Business Impact.
2. Create the record with a clear title, owner, applicable scope, and supporting details.
3. Save and inspect the configured lifecycle state.
4. Where a transition is governed, initiate the required workflow and obtain approval.
5. Review the record history and related risk context.

Example: Example: Create an NYDFS-related obligation, a privileged-access control test, a temporary exception with expiry, or a Business Impact record with recovery targets.

Verification: Expected: The record appears under the selected type and follows its configured lifecycle.

Cautions: Enterprise IRM is currently a generic record-management workspace, not a specialized fully integrated module for every record type. Links to risks are not universally automatic.

24. Workflows

Route controlled decisions to designated approvers.

Step-by-step

1. Open Workflows and create a workflow definition.

2. Specify approval steps and authorized approvers.

3. Publish the definition when ready.

4. Initiate a run for the relevant governed enterprise record.

5. Have approvers record decisions and verify completion before attempting the governed transition.

Example: Example: A material risk exception requires risk-owner review followed by CISO approval before activation.

Verification: Expected: The run history shows decisions and the lifecycle transition is allowed only after the required approval.

Cautions: Do not assume a generic approval grants permission for every transition; verify the workflow target and state binding.

25. Bulk Import: choose the right template

Create many structured governance records efficiently.

Step-by-step

1. Open Bulk Import from the left navigation.

2. Choose Controls, Policies, Frameworks, or Framework requirements.

3. Select Download CSV Template.

4. Replace the example row with your own records without changing the header names.

5. Save as UTF-8 CSV, not XLSX.

Example: Example: Prepare 250 IAM controls in one Controls CSV; create the associated framework separately before importing its requirements.

Verification: Expected: The template contains the columns required for that record type.

Cautions: Bulk Import accepts structured CSV. Use the separate Document Extraction workspace for reviewed PDF/DOCX/TXT controls, frameworks, policies and requirements. XLSX import remains unavailable.

26. Bulk Import: controls CSV worked example

Import controls with explicit status and ownership.

Step-by-step

1. Prepare header: code,title,description,owner,status.

2. Use unique control codes and allowed statuses: planned, implemented, retired.

3. Quote CSV values containing commas and preserve UTF-8 encoding.

4. Validate/Preview before import.

5. Inspect Controls after the import commits.

Example: Example rows: IAM-001,Multi-factor authentication,Enforce MFA for privileged access,IAM Team,implemented; IAM-002,Privileged access reviews,Review quarterly,Security,planned.

Verification: Expected: Each valid row creates one control in the current tenant.

Cautions: A duplicate code is rejected; existing records are not overwritten. An imported implemented status is not evidence of effectiveness.

27. Bulk Import: policies CSV worked example

Import draft policies without falsely claiming approval.

Step-by-step

1. Prepare header: code,title,body,owner.
2. Place the policy text in the body field; quote multiline or comma-containing CSV cells correctly.
3. Validate the file and correct errors.
4. Import and open Policies to verify.
5. Route imported drafts through the applicable approval process.

Example: Example: POL-001,Access Control Policy,"Privileged access must be approved and reviewed.",Security.

Verification: Expected: Imported policies are created as drafts.

Cautions: A policy body in CSV is not the same as ingesting and parsing a signed policy document. Approval does not occur automatically.

28. Bulk Import: frameworks and requirements

Preserve framework revision and reference relationships.

Step-by-step

1. Import a Frameworks CSV with header name,revision.
2. Verify the framework exists in the selected tenant.
3. Prepare a Framework requirements CSV with header framework_name,framework_revision,reference,text.
4. Ensure framework name/revision matches exactly.
5. Validate, import, and verify references.

Example: Example: Frameworks row "NIST CSF,2.0"; requirement row "NIST CSF,2.0,GV.OC-01,Approved requirement text from the authorized source."

Verification: Expected: Requirements are associated with the pre-existing framework revision.

Cautions: Do not invent regulatory text. The framework must exist first; requirements with missing parents are rejected.

29. Bulk Import: validation, limits, and recovery

Safely correct errors before committing.

Step-by-step

1. Select a CSV and click Validate / Preview.
2. Review row-numbered validation messages and fix invalid headers, missing values, or duplicates.
3. Re-run preview until successful.

4. Click Import validated records; server revalidates and commits the entire batch.

5. Verify created count and retain the approved source CSV for audit.

Example: Example: Row 17 duplicates IAM-001; correct the duplicate code and preview again. If the file has 1,200 rows, split it into batches of at most 1,000.

Verification: Expected: Preview does not change the database; a successful import commits all valid rows as a single transaction.

Cautions: File limit: 2,000,000 bytes; no fixed row-count ceiling. A validation failure rejects the batch; HTTP 401/403 indicates authorization, 413 size, 415 format, 422 validation.

30. Troubleshooting and support evidence

Collect useful diagnostics without leaking secrets.

Step-by-step

1. Record the exact navigation path, operation, timestamp, and user role.

2. Check system logs for HTTP failures and operations logs for committed business events, if permitted.

3. For AI errors, run the supported AI connection/status commands and verify the configured model is available.

4. For import errors, retain the row-numbered preview output and a sanitized sample CSV.

5. For login/MFA errors, avoid sharing passwords, MFA seeds, tokens, or full configuration secrets.

Example: Example: AI evaluation returns "invalid or unsupported assessment"; capture model identifier, timestamp, and sanitized system-log exception.

Verification: Expected: Support can reproduce the issue without receiving confidential credentials.

Cautions: Configuration is loaded at service startup; restart after changing logging configuration. Central syslog forwarding is best effort and must be tested against the actual collector.

31. Entra ID and AD FS sign-in

Select the organization, then choose the configured Entra/OIDC or AD FS/SAML button. An identity-provider login does not provision a local account or assign a role automatically. The administrator must bind the immutable identity first. Required MFA applies to both providers. The successful browser callback opens the workspace without placing the bearer token in the URL. If the provider is not listed, contact the deployment operator; do not share credentials in support tickets.

32. Required MFA enrollment and recovery

Local enrollment is optional on fresh installations (LEXIGRID_REQUIRE_LOCAL_MFA=0). Sign in with a password and add an authenticator later in Security. Existing deployments may explicitly retain mandatory enrollment. When required MFA is not enrolled, password login supplies an enrollment-only credential. Scan the QR code and confirm the authenticator code; successful confirmation completes sign-in with a new session. That credential cannot read or change ordinary records. If a valid code was just used, wait for a new code rather than reusing it concurrently. Revoke sessions from Security when appropriate; use the owner-administration recovery procedure for account recovery without exposing seeds or original encryption keys.

33. Reviewed PDF and DOCX extraction

Open Document Extraction, choose Controls, Frameworks, Policies or Requirements, and select the source. Review the editable candidates, source locations, warnings and source hash. Fill missing owner/revision/code/title fields and select only reviewed records. Requirements need an existing framework in the current tenant. Import the selection, then verify its destination workspace and audit events. Changing the source or type clears the previous preview. Conflicts preserve the preview and do not overwrite existing records. Controls remain planned and policies remain draft.

For the verified ISO/IEC 27001:2022 PDF, Frameworks identifies the standard/edition, Requirements returns management-clause candidates, and Controls returns 93 Annex A candidates under A.-prefixed references. Copyright/front matter is excluded. Policy mode explains that the standard is not your organization's policy. Counts are source-specific, not a universal accuracy promise. See the document extraction manual for limits, OCR and complex-layout cautions.

For a complete document batch, use Select all in the preview, check the selected count, then use Import and the in-page Confirm import button. Clear selection cancels a pending confirmation. A successful requirements import offers Open target framework; failures show a request reference.

34. Failed notification recovery

A failed risk email or workflow channel is visible in its history/recovery controls. A permitted tenant administrator or risk manager may request one additional attempt with a reason after correcting the delivery problem. Refresh before retrying a stale attempt count. The action is audited and attempts are cumulative. Workflow channels retry independently; a successful channel is not resent because another channel failed. An expired lease can mean remote acceptance already occurred, so duplicates remain possible.

35. Evidence download errors

HTTP 503 means a provider/configuration/access operation could not complete; retry after the operator restores access to the original key/provider. It is not proof that the evidence is corrupt. HTTP 409 means an integrity check/envelope/hash could not be validated. Never replace evidence or regenerate keys merely to clear either error. Retain the record identifier, timestamp and sanitized error for the operator.

Import requirements when no framework exists

Requirements must belong to a target framework. If the target list is empty, enter the framework name and its actual revision / edition directly on Document Extraction and select **Create framework and use as target**. Creating a target does not import requirements. It preserves all extracted rows, edited text and selections. Choose **Import selected reviewed requirements**, review the target and count, then choose **Confirm import**. **Select all** approves every extracted row for the same review flow.

If you click Import without a target, the page explains the missing framework and focuses its name field. A failed framework creation leaves the preview intact and shows an error with its request reference. Framework creation and requirement import are separate audited transactions; the missing-target UI event is also logged without document contents.

Exact CSV formats shown on the import screen

The Record type selector controls the displayed columns, rules, example and matching Download button. A framework CSV correctly has only two columns: it creates framework identities, not controls or policies. Use one file for each record type. Templates contain static fictional sample rows, never an export of your existing organization records. Replace the sample row before importing.

Record type	Required CSV header row
Controls	code,title,description,owner,status
Policies	code,title,body,owner
Frameworks	name,revision
Framework requirements	framework_name,framework_revision,reference,text

All listed columns must be present; names are case-sensitive and column order may vary. Save as UTF-8, comma-delimited CSV. Use one record per row, quote values containing commas or line breaks, and double embedded quote characters. Keep codes and revisions as text in Excel. XLSX files are not accepted. There is no fixed row-count ceiling; the file limit is 2,000,000 bytes. Existing records are not overwritten.

Controls example

```
code,title,description,owner,status
EXAMPLE-CTRL-001,Example account review,Review privileged access every quarter.,Example Security
Team,planned
```

Status must be planned, implemented or retired. The page displays each field's actual minimum/maximum length.

Frameworks example

```
name,revision
Example Security Framework,2026.1
```

These two columns are the complete framework format. Import requirements separately after creating the framework.

Policies example

```
code,title,body,owner
EXAMPLE-POL-001,Example access policy,"Grant access by role, and review it quarterly.",Example
Security Team
```

The quoted policy body includes a comma. New policies start in draft state; import does not approve them.

Framework requirements example

```
framework_name,framework_revision,reference,text
Example Security Framework,2026.1,EXAMPLE-REQ-001,Review privileged access every quarter.
```

The framework name and revision must exactly match an existing framework in the current organization. Import the framework first. A requirement reference must be unique within that framework.

Run Validate / Preview, correct every reported error, then choose Import validated records. Changing the record type or selected file invalidates prior validation. The download stays associated with the type chosen when downloading even if the selection changes during the request. If the format guide fails to load, use Retry loading CSV formats; errors include a request reference.

Review and explicitly apply an AI assessment

AI generation creates a proposal and leaves the official risk unchanged. The panel shows current likelihood/impact/score, the evidence-checked proposal, confidence, linked-control/test counts, information gaps and limitations. The original model estimate and narrative remain available when evidence checks change the proposal; they are not the values adopted by the Apply action.

Evidence checks for the current rating

A missing process, planned control, filename/hash, user attestation or proposed treatment does not establish lower current exposure. For example, a risk at likelihood 5 and impact 5 remains at score 25 when a model suggests 4 and 4 but only a planned control and no test results support it. The panel records low confidence and explains the retained dimensions. A raw model can still produce incorrect numbers or prose; these checks are conservative product rules, not a calibrated prediction or compliance certification.

Reductions are checked separately for likelihood and impact. Each reduced dimension needs a model reason and cited supporting records. Current control-effectiveness support requires an implemented linked control, its latest passing test within 90 days, references to both, and no unresolved high/critical finding for that control. Alternatively, a recent human-recorded inherent/residual assessment made after the last risk edit can support a correction no lower than that assessment's dimension. Future target assessments and prior AI-adopted assessments do not independently corroborate a reduction. Unusable optional model justifications are discarded; invented top-level evidence references and invalid required scores remain rejected. The 90-day window is the current application evidence-check policy, not an assertion about a standard's mandated testing interval.

Keep the current assessment

1. Open Risks > Manage and review the proposed assessment and its evidence checks. Scroll inside the dialog to see the choice controls.

2. Optionally enter a review note.

3. Select **Keep current assessment**.

4. The proposal is recorded as rejected/declined. The official likelihood, impact and risk version remain unchanged, and no new residual assessment is created. The decision and actual user are audited.

Apply the reviewed AI assessment

1. Review the checked likelihood/impact/score, confidence, rationale, proposed treatment/actions and gaps.

2. Select **Apply AI assessment**. The interface displays the exact current-to-proposed score comparison.

3. Select **Confirm and update risk**, or **Cancel** to return without applying.

4. On confirmation, the server uses the saved, provenance-bound checked dimensions. It updates the official likelihood/impact, increments the risk version, creates a residual assessment with its rationale and actual human assessor, and records the proposal as accepted. The original proposal author is retained.

5. The register is refreshed and reports/dashboard reads use the new official rating. Existing opted-in risk-change notifications follow the normal transaction-safe queue. Proposed treatments/actions remain recommendations; applying does not mark them completed or create invented due dates. Risk title, description, owner, category and lifecycle status are retained.

If evidence checks retained the current score, applying can legitimately preserve the same numeric score while saving the reviewed assessment and decision. For example, both scores can be 25 because no effective mitigation is demonstrated. A supported 4-by-4 proposal applied to a 5-by-5 risk changes the official score to 16.

Permissions, approvals and stale proposals

Only users with the existing risk-edit permissions (platform/tenant administrator, risk manager or risk editor) can decide. Apply is an explicit human risk-edit action; it is not automatic model approval. If a formal workflow has already been started for this proposal, its latest run must provide an unconsumed approval for this exact record version/content and the accepted target state. An unbound, pending, rejected or stale approval cannot be bypassed. Generic Enterprise IRM Review opens the risk panel; generic transitions cannot manufacture an accepted AI state without adopting through the checked decision path.

A changed risk version, changed linked evidence/answers, closed risk, altered payload, invalid signature or expired support blocks applying. Evaluate again and review the new proposal. Historical proposals produced before the current evidence policy are retained but require reassessment before adoption. Keep can decline such a proposal without overwriting the current risk. Duplicate or competing decisions do not create a second assessment or overwrite a newer risk. Request references identify failures; a failed transaction leaves the risk, assessment history, decision and queued notifications unchanged.

Provenance binds the stored proposal to its recorded digest and, when audit signing is configured, its valid audit signature. It authenticates the saved record, not the truth of the model's judgment. PostgreSQL timestamps are normalized to UTC for verification of existing UTC-signed audit entries; no audit history or stored signatures are rewritten.

Control defaults and existing records

For controls or policies, Default accountable owner supplies blank individual owner values. Keep the owner CSV column; a nonblank row owner overrides the default. Re-run preview after changing the default. Existing controls and later repeated codes are listed as skipped; new controls continue without overwriting the original records. New-row validation errors still prevent committing the new rows. Framework, policy and requirement conflicts keep their existing safeguards.

View and add requirements

Open **Requirements**, choose an existing framework, and review its requirement list. Use **Add requirement** to enter a reference and requirement text, then save. Use Edit to update a requirement. Create a framework first if none exists. Editing requires the existing framework-management permission.

Find requirements across the workspace

Open **Requirements** between Frameworks and Policies. The page opens across all frameworks unless an import or prior selection selected a framework. Use **All frameworks** to return to the complete workspace list. Search by reference, requirement text or framework name; Previous and Next page through results. Choose a framework to enable Add requirement. Existing requirements can be edited by authorized users. Expand **Requirements API** for the exact API routes.

Editing records in LexiGrid 5.54.15

The Risks, Controls, Frameworks, Policies, and Enterprise IRM workspaces now provide Edit actions. Framework requirements can be added and edited in Frameworks. These changes do not enable arbitrary editing of approvals, signed evidence, or immutable audit history.

Risk example

1. Sign in as a tenant administrator, risk manager, or risk editor.

2. Open Risks, locate the risk, and select Manage, then Edit risk.

3. Change its title, description, category, owner, likelihood, impact, or non-closed status.

4. Select Save changes. LexiGrid recalculates risk scoring in its existing API and records the update in its audit history.

5. If another user has updated the record, refresh the page and retry. LexiGrid rejects stale versions rather than overwriting newer changes.

6. To close a risk, use Resolve & Close and supply a justification. Editing cannot bypass the closure workflow.

Example: Change an authentication risk likelihood from 4 to 3 after documenting effective compensating controls. Reassess with AI separately; AI recommendations do not automatically change the official rating.

Control example

1. Open Controls and select Edit on the relevant control.

2. Change the code, title, description, owner, or lifecycle status.

3. Save. Duplicate codes are rejected. Stale versions are rejected with a conflict error.

4. Verify the revised control in the list and the corresponding operation in Audit.

Framework example

1. Open Frameworks and select Edit.

2. Change the framework name or revision, then Save changes.

3. Duplicate name/revision combinations are rejected. Existing linked requirements remain attached to the same framework ID.

4. Select the framework in Requirements, then choose Add requirement or Edit. Save the reference and requirement text.

5. API clients must send the version token returned by GET when PATCHing a framework or requirement. A stale token returns 409; reload and review the newer record before retrying.

Policy example

1. Open Policies and select Edit for a draft policy.

2. Update the code, title, policy text, or owner and Save.

3. Policies under review, approved, or retired cannot be edited directly. This prevents bypassing the approval lifecycle. Return a policy to draft using the governed transition where permitted, or initiate a new controlled revision process.

Enterprise IRM example

1. Open Enterprise IRM and choose the record category.

2. Select Edit beside the desired record; change title, owner, and data fields.

3. Save. The API checks tenant, authorization, record kind, required data fields, and record version.

4. Use Review for lifecycle transitions; the Edit action does not advance workflow state.

Security and operational notes

- Tenant boundaries are enforced server-side.

- Edit permissions are enforced by backend authorization, not only hidden UI buttons.

- Risk, control, policy, and Enterprise IRM edits use optimistic version checks.

- Framework and requirement edits require content-version tokens and reject stale updates atomically.

- Approvals, evidence files, and audit records remain governed by their existing APIs and should not be silently overwritten.

- Vendor, business-service and loss-event data use the Enterprise IRM record editor.

- During upgrades, preserve the database and configuration. The change adds no database migration.

Risk change history

Choose **Manage -> Change history** for a read-only list of committed creation, edits, AI-applied score changes and closure. Expand before/after values and inspect each event's audit signature status. A valid signature does not prove complete history; absent historical values remain absent. API: `GET /api/risks/{id}/history?limit=50&offset=0`.

Reviewed document import

Use **Document Extraction** to import controls, frameworks, policies, or requirements from text-based PDF, DOCX and UTF-8 TXT files. Select the record type before extraction. Changing the file or type clears the old preview. Extraction does not save records and all approval checkboxes start unchecked.

What to review

- **Controls:** review code, title, description and owner. Numbered/control-code headings and recognized table columns are supported, including common references such as AC-2, AC-2(1), A.5.15, CC6.1 and GV.OC-01. Descriptions need not contain "must" or "shall." Numbered actions under a control remain with that control. If a single statement lacks a separate title, the title stays blank for review. The optional default owner is entered by the user and fills only missing source owners.

- **Frameworks:** review name and revision. Recognized table headers and explicit document labels such as `Framework:` and `Version:` are supported. Missing revisions stay blank; a revision is not inferred from an arbitrary date in the document.

- **Policies:** review code, title, body and owner. Recognized policy tables can provide multiple policies. Otherwise a document-level policy candidate preserves the complete extracted text, including its sections. Missing metadata stays blank. A document containing multiple separate policies in an unrecognized layout should be split or prepared as a supported table rather than assuming automatic policy boundaries.

- **Requirements:** review reference and full text, then select an existing target framework in the current tenant. Recognized requirement tables and numbered normative clauses are supported. Framework existence and tenant ownership are checked again on import.

Candidate cards show a source page/line or DOCX block/table-row location and extraction warnings. PDF extraction preserves spacing for column mapping and wrapped descriptions. DOCX paragraphs and tables are read in document order. The extractor maps recognized column headers rather than assigning fields solely from their position. Unrecognized tables/aligned columns produce warnings. This is a deterministic source parser, not an authoritative standards interpretation or a model-derived accuracy score.

Repeated identifiers remain separate candidates with warnings. Review and consolidate the source content or select the appropriate occurrence; duplicate identifiers cannot be imported as separate records in the same scope. Text is not silently cut to fit destination fields. If a destination limit is exceeded, the import is rejected and the preview remains available for correction. Controls allow descriptions up to 10,000 characters; policies allow bodies up to 100,000 characters. A single extraction is limited to 1,000 candidates; split larger documents.

Select all and complete the import

1. Extract candidates for the intended record type and compare them with the source.

2. Fill missing required fields. For requirements, choose the existing target framework.

3. Choose **Select all** to include every extracted candidate, or select individual approval checkboxes. **Clear selection** removes every selection and cancels an older confirmation. Neither action imports data.

4. Check the selected-record count, then choose **Import selected reviewed requirements/controls/frameworks/policies**.

5. Check the count and target in the in-page confirmation, then choose **Confirm import**. Native browser confirmation dialogs are not used. **Cancel** leaves the database unchanged.

6. Wait for **Imported N reviewed records** and retain the import reference. For requirements, **Open target framework** displays the saved records.

7. If an error appears, retain its request reference for your administrator. A network interruption can leave the result uncertain: check the target before retrying. Existing controls are skipped without changes; check the receipt for created and skipped counts. Existing framework, policy and requirement conflicts reject the batch without partial writes.

Select all includes all candidates for the currently chosen record type. It does not remove required-field checks or automatically approve a standard as an organization policy. Controls remain planned and policies remain draft after a reviewed import.

Import behavior

Select only reviewed candidates and complete every required field. Import validates the full selection before creating records. Invalid new rows or an invalid framework prevent the batch from being imported. Existing control codes and later repeated control codes are recorded as skipped while new controls continue; original controls are not overwritten. Other record types retain their conflict safeguards. Conflicts do not discard the preview. Unexpected database errors roll back the transaction. Each successful record has an audit event identifying the reviewer and source file SHA-256.

Controls are created as **planned** and policies as **draft**, preserving their existing lifecycle and review requirements. Import does not approve or publish a policy and does not automatically link controls to frameworks. Tenant administrators and risk managers may extract/import; ordinary viewers may not. Existing CSV import and the reviewed-requirement endpoints remain available.

Scope and limitations

The upload limit is 8 MB, with at most 1,000 selected PDF pages and 2,000,000 source-text characters per review (generated layout spacing excluded), and bounded DOCX archive expansion. Image-only/scanned PDFs must undergo OCR before upload. Complex multi-column reading order, unusual tables, automatic Word numbering, embedded images and nested layouts may require source preparation or manual review. An empty candidate list is not a statement that a document contains no obligations.

Validate representative PDF and DOCX files against their original sections and table columns before importing. Source files and content are not sent to an external extraction or AI service.

ISO/IEC 27001:2022 PDFs

When the PDF's source content identifies ISO/IEC 27001:2022 and its Annex A structure, a dedicated profile uses content-stream text instead of layout-mode spacing. This avoids fragmented words from justified typography. It excludes cover/copyright material, contents/front matter, publisher page furniture and the bibliography from candidate records.

Choose **Frameworks** for the standard identifier and edition, **Requirements** for normative management clauses in sections 4-10, or **Controls** for Annex A table rows. Annex control references are namespaced as `A.5.1`, etc., so they cannot be confused with management clauses such as `5.1`. Wrapped titles, the table's `Control` column marker and split source

references are handled separately. The detected standard is displayed in the preview. Counts describe what was extracted; the profile does not fabricate missing rows to meet a target.

Choosing **Policies** for this standard returns no organization policy and explains why: a standard sets policy requirements but does not contain your organization's approved policy text. Import its controls/requirements and draft your organization policies through the normal lifecycle.

For ISO/IEC 27001:2022, verify that the review separates the framework, management requirements and 93 Annex A controls (37 organizational, 8 people, 14 physical and 34 technological). Different editions, translations, scans and encodings require their own review. Missing ownership must be assigned explicitly. The standard is not an organization-approved policy. Licensed source documents are not included in this distribution.

Refresh the browser after an upgrade before re-extracting documents so the typed preview and detected-standard label are loaded. Previously imported records are not automatically deleted or replaced.

Import requirements when no framework exists

Requirements must belong to a target framework. If the target list is empty, enter the framework name and its actual revision / edition directly on Document Extraction and select **Create framework and use as target**. Creating a target does not import requirements. It preserves all extracted rows, edited text and selections. Choose **Import selected reviewed requirements**, review the target and count, then choose **Confirm import**. **Select all** approves every extracted row for the same review flow.

If you click Import without a target, the page explains the missing framework and focuses its name field. A failed framework creation leaves the preview intact and shows an error with its request reference. Framework creation and requirement import are separate audited transactions; the missing-target UI event is also logged without document contents.

Large PDF documents and page ranges

The old 250-page rejection is removed. Leave PDF start/end pages blank to process the complete document when it fits the per-review limits. Enter one-based inclusive page numbers to process a range (for example, 251 to 500). A blank start means page 1; a blank end means the final page. Page ranges apply only to PDF files. The result names the processed range and total page count; partial results explicitly warn that the remaining pages were not assessed. Candidate locations retain original PDF page numbers.

Review and import a range before extracting the next range, because a new extraction replaces the current unsaved preview. Use contiguous boundaries when numbered records continue across pages; inspect boundary records against the source before import. If a single record spans a boundary, include it in one reviewed range and avoid selecting duplicate references in the other. No automatic truncation or automatic import is performed. There is no fixed candidate or reviewed-record count ceiling. The 2-million source-text-character budget remains; reduce the range if the actual source exceeds it. The upload limit remains 8 MB, including when selecting a range from a large source PDF. HTTP errors retain their request ID in system and operations logs. Completion logs include processed start/end and total page count without source document text.

NIST SP 800-53 Revision 5 catalogue extraction

The Revision 5 PDF is recognized from its publication identity. The dedicated profile reads Chapter Three control statements in source order, including enhancement identifiers such as AC-2(1). It excludes the cover/front matter, explanatory Discussion and Related Controls sections, references and Appendix C summary tables. Withdrawn entries are omitted with an explicit count; they must not become planned active controls. Owners remain blank until you supply an accountable owner. The standard is not an organization policy: choose Controls or Requirements for its statements, or Frameworks for its publication identity.

For the 492-page NIST SP 800-53 Revision 5 PDF tested for this release, the review contains 1,007 active statements: 298 base controls and 709 enhancements. The profile omits 182 withdrawn entries. The full file can be reviewed in one extraction and one reviewed import; document review/import has no fixed record-count ceiling. CSV retains its separate file-size limit and has no fixed row-count ceiling. Review all extracted fields, set Default owner before extraction when appropriate, select records or Select all, then select Import and Confirm import. No controls are saved by extraction alone. Existing control codes are noted and skipped while new controls continue; existing policies, frameworks and requirements retain their existing conflict safeguards.

When using a page range, include the control heading and its complete statement. A range beginning inside an enhancement cannot establish its parent identifier; incomplete fragments are not invented as records. Original PDF page references remain attached to candidates.

PDF layout padding and extraction diagnostics

The PDF parser no longer emits artificial vertical blank-line padding. For generic tables, horizontal spacing still preserves column alignment, but generated spacing does not consume the source-text budget. A separate 64-million-character layout expansion guard bounds generated layout storage. The 8 MB upload, 1,000 selected-page and 2-million source-text limits remain explicit; no review is silently truncated.

Completion logs include plain-text, layout and content character counts together with the selected page range. Extraction rejections record these safe metrics and their HTTP status under the request ID; source document text and filenames are not logged. The NIST structural profile reads source-order text directly, avoiding layout padding and rotated publisher furniture. Existing imported data is preserved; refresh the browser and re-extract the original file after upgrading.

Choose the record type and verify the destination

Document Extraction now opens with **Choose records to create**. Choose the record type explicitly before extracting:

- **Controls** creates records in the **Controls** tab. Supply an accountable owner before import, using Default owner for missing owners when appropriate.

- **Requirements** creates records under **Frameworks -> selected framework -> Requirements**. Selecting a framework does not create control records. The Requirements navigation tab also provides viewing, adding and editing for the selected framework.

- **Frameworks** creates records in the **Frameworks** tab.

- **Policies** creates records in the **Policies** tab.

The destination is shown beside the type selector, in the extraction summary, and again before confirmation. For a detected standard, compare its identity with the chosen destination framework before proceeding. Intentional mappings to another framework remain possible; the product does not silently reclassify or move records.

After a successful import, the receipt identifies the destination and provides **Open Controls**, **Open imported requirements**, **Open Frameworks** or **Open Policies**. The requirements action opens the selected framework's requirements. Controls also offers **Import controls from a document**, which explicitly selects Controls in the extraction page. An empty Controls list explains that requirement imports are listed under Frameworks.

If a previous import completed but is absent from Controls, check its receipt or Frameworks requirements first. Existing requirements remain in their original framework. To create controls from a source standard, choose Controls and perform a separate reviewed import with explicit ownership. Do not assume that a successful Requirements import created controls.

Default accountable owner and duplicate control imports

Enter Default accountable owner before or after extraction. All rows that have no individual source/review owner inherit it. Changing the default updates inherited review fields; explicit individual owners remain unchanged. Clear an individual owner to restore inheritance. Changing the default cancels any pending confirmation so the final owner values must be reviewed again. The server applies the same fallback when an individual owner is omitted or blank in an API request. Policies use the same explicit-owner fallback; frameworks and requirements do not acquire invented ownership fields.

Existing controls are identified by exact, case-sensitive code within the current workspace. The review labels known existing codes. They are skipped without changing their owner, description, status, version or authorship. New controls continue importing; a repeated code inside one batch keeps its first occurrence and skips later occurrences. The server rechecks uniqueness at insertion, so an overlapping concurrent import is also treated as a skip. Completion reports created/skipped counts and lists each skipped code with its reason. These decisions are audited. A batch containing only existing controls succeeds with zero created records. Invalid new rows still prevent the new writes from being committed; duplicate skipping is not permission to save invalid data.

The same owner and duplicate-control rules apply to CSV import. Keep the owner column in the downloaded template; leave cells blank to inherit Default accountable owner, or specify an individual row owner. Changing the default after preview requires another preview. Existing policies/frameworks/requirements keep their original conflict behavior. CSV file-size limits remain; there is no fixed CSV row-count ceiling.

CJIS Security Policy version 6.1

CJIS is one published policy. Policies extraction retains all extracted text of the selected pages, including appendices when selected, as one draft policy candidate. For the authorized 473-page version 6.1 PDF, this is over one million characters; the body is retained rather than truncated into thousands of spurious table fragments. The accountable owner is supplied locally; publisher attribution does not become the importing organization's owner or approval.

Frameworks extraction returns the FBI CJIS Security Policy identity and version 6.1. Controls and Requirements extract 308 main-policy provisions: 292 control/control-enhancement statements and 16 normative mobile-device clauses. Source control references are preserved. Control codes use a CJIS- prefix to keep CJIS-specific provisions distinct from NIST controls with similar identifiers; requirement references remain scoped to the selected framework. Introductory context, discussion, examples and appendices remain available in the full policy text and are not invented as separate control requirements. This is source extraction, not an assertion of CJIS compliance or local implementation.

Requirements navigation

Open **Requirements** in the navigation menu. Choose the framework to view its requirements. Authorized users can choose **Add requirement**, enter its reference and text, and save it; existing entries can be edited through the same version checks used under Frameworks. If there is no framework, use **Create a framework** first. Read-only roles can view requirements. Requirements remain associated with their framework and can also still be viewed under Frameworks. The document-import receipt opens the selected framework directly in Requirements.

Risk assessment methodologies and reports

Author: Shahryar Jahangir, Aniza Inc.

Perform a single-risk or batch assessment

1. Open **Risk Assessment** from the navigation menu. Select an assessment methodology. Read its scope notice and official reference link.

2. Select one or more defined risks, with no fixed risk-count ceiling. Previous/Next pages retain the selection; Clear selection resets it. Risks remain within the current workspace.

3. Expand each selected risk's scenario inputs. Provide scope, relevant assets, threat scenarios, vulnerabilities, organization acceptance criteria and sector details. Treat these entries as assertions; link control tests and other records from the risk to supply supporting evidence.

4. For FAIR, optionally provide every financial factor range and its estimation basis as described below. Leave all financial inputs blank to receive a missing-data analysis without invented monetary estimates.

5. Select **Assess selected risks**. Keep the page open while each selected risk is processed by the configured AI provider. The selected methodology is different from the language model: provider/model and air-gapped/cloud controls remain administrator settings.

6. Review the saved report's status, per-risk findings, confidence, evidence checks, gaps and proposed treatment. Failed or stale items are explicitly marked; retry those risks after resolving the cause. Successful risks remain available in partial reports.

7. Download JSON, PDF or CSV from the report. Saved reports preserves the assessment-time snapshot; later edits do not rewrite it. The most recent 100 reports are listed.

8. To accept a successful risk's proposed ordinal rating, select **Review rating: Keep or Apply**. This opens the shared review panel without running a different assessment. It identifies the methodology and offers Keep current assessment or Apply AI assessment. Apply requires explicit confirmation and rechecks current risk/evidence versions, provenance, permissions and any bound approval workflow. Financial estimates and proposed treatments remain advisory. Historical reports continue to show their original official-rating snapshot after adoption.

Risk administrators, managers and editors may run assessments. Other authenticated workspace members may read and export saved reports. Each creation, proposal, adoption decision and export is audited; errors retain request references. No rating changes merely because a report was generated or downloaded.

Available methodology profiles

Methodology	Analysis performed	Scope and limits
NIST SP 800-30 Rev. 1	Threat sources/events, vulnerabilities and predisposing conditions, event and adverse-impact likelihood, impacts, uncertainty and monitoring	Structured qualitative profile using LexiGrid's disclosed five-point scale. NIST does not prescribe one universal ordinal product matrix.
FAIR / Open FAIR	Loss scenarios, threat-event frequency, vulnerability probability, primary/secondary loss and data quality, plus reproducible range calculation	User-supplied quantitative factors are required for money estimates. This is a LexiGrid implementation of FAIR concepts, not a certified Open FAIR tool.
ISO/IEC 27005:2022	Context/criteria, asset-threat-vulnerability scenarios, identification, analysis, evaluation, treatment, communication and review	Organization criteria must be supplied. No licensed standard text or conformity assertion is included.
HHS Security Risk Assessment	ePHI assets/vendors, administrative, physical and technical safeguards, threats, impacts and remediation	HHS SRA-informed analysis; not the official SRA application, exhaustive questionnaire or HIPAA compliance determination.
FFIEC CAT (legacy)	Inherent-risk considerations and the five cybersecurity maturity domains, with evidence gaps	FFIEC retired CAT on August 31, 2025. A selected-risk report cannot determine institution-wide CAT maturity.
CISA Infrastructure Survey / resilience screening	Facility threat scenarios, physical protections, security management, dependencies, cascading impacts, recovery and missing observations	IST-informed desk screening. It does not conduct a site inspection, official CISA survey, peer comparison or protective/resilience index.
CISA Cybersecurity Performance Goals	IT/OT scope, governance/identification, protection, detection, response, recovery and prioritized outcomes	CPG-informed analysis rather than an official CSET module or complete CPG checklist. Validate proposed mappings against the current publication.

Every profile requires its own analysis sections. The server rejects incomplete structured responses after one retry, rather than presenting generic text as a successful methodology assessment. AI statements and mappings require review against the cited records; file metadata and assertions are not verified effectiveness. Unsupported reductions in current likelihood or impact are held at the existing rating. The unadjusted model estimate is separately retained.

FAIR quantitative assumptions and output

For each risk, enter a three-letter currency code and low / most likely / high values for: threat events per year; vulnerability (probability a threat event becomes a loss, from zero to one); primary loss per event; probability of secondary loss (zero to one); and secondary loss when it occurs. Include the data sources, observation period and assumptions in the basis field. All ranges must be ordered and nonnegative. Zero is a valid value. Partial ranges are rejected. Different risks may use different assumptions or currencies; the product does not add them into an unsupported portfolio total.

The server computes annualized expected loss as annual threat-event frequency multiplied by vulnerability multiplied by primary loss plus probability-weighted secondary loss. Independent triangular distributions are used for low/most-likely/high inputs, with 10,000 seeded draws; constant ranges remain constant. The report preserves the inputs, deterministic seed, formula, analytic mean and P10/P50/P90 uncertainty values. These percentiles describe uncertainty in annualized expected loss, not annual aggregate loss percentiles or value-at-risk. Independence and stable annual rates are assumptions to validate; AI does not supply missing financial factors. The five-point ordinal rating is reported separately and is never converted into money.

Export contents and interpretation

JSON preserves the report envelope, author, method/version, provider/model, scenario inputs, per-risk source snapshots, evidence references, input/output hashes, analysis, checked ratings, gaps and quantitative assumptions/results. CSV uses a lossless two-column field/value layout with indexed paths for nested risks and factors; spreadsheet formula prefixes are escaped. PDF presents readable methodology findings, ratings, scenario inputs, evidence checks, gaps, financial factors/results and provenance hashes across numbered pages; JSON retains the complete machine-readable source snapshots. Supplied markup is escaped. All three formats are downloadable from the same saved report and record an export audit event. Failed/stale item statuses and missing-data notices remain in exports.

Official references

- NIST SP 800-30 Rev. 1 (2012): https://csrc.nist.gov/pubs/sp/800/30/r1/final

- The Open Group Open FAIR risk-analysis publication: https://pubs.opengroup.org/security/o-ra/

- ISO/IEC 27005:2022 publication description: https://www.iso.org/standard/80585.html

- HHS/ONC SRA tool and its limitations: https://healthit.gov/privacy-security/security-risk-assessment-tool/

- FFIEC CAT sunset notice: https://www.ffiec.gov/news/press-releases/2024/an-09-29

- CISA Infrastructure Survey Tool: https://www.cisa.gov/resources-tools/services/infrastructure-survey-tool-ist

- CISA Cross-Sector Cybersecurity Performance Goals:
https://www.cisa.gov/cross-sector-cybersecurity-performance-goals

References checked November 6, 2026. These profiles are advisory adaptations, not official agency applications, examinations, certifications or licensed reproductions.

Deployment and runtime behavior

Assessment calls are synchronous and process the selected risks sequentially without a fixed risk-count ceiling, with a 90-second provider read timeout and at most one schema-repair retry per risk. Large local-model batches can therefore take longer in proportion to the number of selected risks. Operators must configure the TLS reverse proxy/request timeout for the selected batch size (allow up to approximately three minutes per risk for two provider timeouts), or use smaller batches. If the connection times out, check Saved reports before retrying: a completed server-side report may already exist. There is no background-job progress or cancellation API in this profile. Source context is bounded to linked-record limits; a report is not an exhaustive assessment of all organizational records.

Automatic risk-to-governance matching

Author: Shahryar Jahangir, Aniza Inc.

Open a risk to scan

Open **Risks -> Manage**. For an authorized risk editor, the **Applicable policies, controls, frameworks and requirements** section automatically checks the current workspace catalogue and generates AI applicability matches. It shows progress, then matched record identities, lifecycle states, confidence, risk-specific reasons and exact supporting quotations. Use **View matched record** to read the current full record and **Back to risk** to return. Frameworks containing a matched requirement are explicitly identified as a derived association; that association does not establish that every provision of the framework applies.

Matching is saved per risk and catalogue snapshot. Opening the same risk reuses current saved matches. Changes to the risk, policies, controls, frameworks or requirements invalidate the snapshot and the next opening rescans. **Rescan**

applicable records requests a fresh model result. Read-only users can view current saved matches; they cannot start model work. A failed or stale scan displays its request reference and can be retried. It does not replace a valid historical scan with invented matches.

Coverage and interpretation

The application text-scans every policy, control, framework and requirement in the authenticated workspace, including all passages of long policy bodies. It ranks candidates using risk terms and related terminology, then asks the configured AI to evaluate a shortlist of up to six records per type using relevant excerpts. The screen reports both full catalogue counts and AI-reviewed counts. Additional applicable records may exist outside the shortlist; this is assisted discovery and must not be treated as an exhaustive regulatory mapping. Empty matches mean no applicable item was identified among the reviewed candidates, not that no obligation exists.

The AI must cite an exact source excerpt and an identifier belonging to a supplied current-workspace candidate. Unsupported references, invented quotations, invalid confidence values and duplicate references are rejected. A bare ID is normalized only when it uniquely identifies one supplied candidate. Record content and risk descriptions are untrusted data, never executable instructions. Parent-framework associations are verified against the requirement's stored framework identity.

Matches are automatically saved applicability associations. They do not change the risk's likelihood, impact, score, ownership or lifecycle. They do not create verified control-evidence links or prove that a draft policy is approved, a planned control works, or a requirement has been satisfied. Use the existing evidence workspace and control tests for verified evidence. Official AI ratings retain the explicit Keep/Apply review process.

Model configuration and data

Matching uses the existing configured AI provider and model. Local Ollama remains the default for air-gapped installations; matching does not enable cloud access or bypass provider configuration. Cloud model use requires the existing explicit administrator opt-in. Automatic matching sends risk text and selected governance excerpts to that configured provider. If the model is unavailable, the rest of the risk screen remains usable and the matching section shows an actionable error.

Scan results identify the provider, model, snapshot, scanned/reviewed counts and limitations. Successful scans are transactionally audited with the reviewer, risk identity, catalogue digest and matched references. Failures and HTTP transactions are logged with request references without copying source policy bodies, prompts, secrets or raw provider responses into logs.

API

All routes require an authenticated current-workspace session or bearer token. Substitute actual IDs.

- `POST /api/ai/risks/{risk_id}/governance-matches` creates or reuses a current scan under the existing risk-edit roles. Add `?force=true` to regenerate.

- `GET /api/ai/risks/{risk_id}/governance-matches` reads current saved matches, or reports `not_scanned` / `stale`.

- `GET /api/requirements?limit=100&offset=0` lists requirements across the workspace, including framework name and revision. The result has `total`, `limit`, `offset` and `items`. Follow pages to read all records; page size may be 1 through 500.

- `GET /api/requirements?q=access&framework_id={framework_id}` searches reference, requirement text or framework name, with an optional framework filter. Search treats percent and underscore literally.

- `GET /api/requirements/{requirement_id}` retrieves a complete requirement and framework identity.

- `GET /api/frameworks/{framework_id}/requirements` retains the existing framework-scoped listing.

- `POST /api/frameworks/{framework_id}/requirements` adds a requirement using `{"reference":"AC-1","text":"Review privileged account access quarterly."}` under existing governance-edit permissions.

- `PATCH /api/frameworks/{framework_id}/requirements/{requirement_id}` edits a requirement with its current content version, reference and text.

Cross-workspace risk, requirement or framework IDs return not found. The interactive API schema remains available at `/docs` on the installation.

Compliance audits: applicability, implementation and effectiveness

Author: Shahryar Jahangir, Aniza Inc.

What the audit does

Compliance Audits creates a separate, versioned audit item for every imported requirement in the selected frameworks. It can also include controls outside those requirement mappings as separate safeguards with no invented standard attribution. The full catalogue is audited; the risk-matching AI shortlist is not used to limit audit coverage. Every item starts as undetermined, unknown and not tested.

The supported workflow can cover an entire imported ISO/IEC 27001, NIST SP 800-53, CJIS or other framework catalogue. Import the exact framework edition and its complete requirements first, review the extraction against the source standard, and establish actual control-to-requirement mappings. A framework identity alone is not a complete safeguard catalogue. Importing controls alone does not establish which framework they belong to. A selected framework with no requirements blocks finalization.

Catalogue completeness is an independent reviewer attestation supported by recorded evidence. LexiGrid cannot prove from an arbitrary uploaded list that no official standard provision was omitted. It does not distribute licensed standards or certify conformity.

The first identity integration provides four Entra checks and seven Active Directory checks. These are narrowly defined observations, not automated tests for every clause of every standard. Organizational, personnel, physical, contractual and other unsupported safeguards require actual documented procedures, observations and evidence. The engine must leave them not tested until that work is performed. An AI applicability match, implementation label, policy approval or file attachment alone cannot automatically establish operating effectiveness.

1. Create the complete scope snapshot

1. Open **Compliance Audits** in the navigation menu.

2. Expand **Create audit**. Enter a title and the systems, organizational boundary and observation period.

3. Select every in-scope framework and exact edition. There is no fixed number of selected frameworks or audit items.

4. Decide whether to include unmapped workspace controls as separate, unattributed safeguards.

5. Select **Create full catalogue snapshot**. Compare the total safeguards with the full source inventory.

The snapshot preserves source references, full requirement text, framework editions, source versions and explicitly mapped controls. New or changed requirements, frameworks or mapped controls are detected. Create a fresh audit snapshot when the source catalogue changes; prior audit evidence and authorship are preserved.

2. Collect supporting evidence

Expand **Record evidence and read-only identity observations**.

- **Upload encrypted audit evidence** records a supporting artifact of 1 byte through 10 MiB. Keep complete procedures, sampling details, source-system identity, observation period and results. Uploaded evidence remains operator-submitted until its provenance is independently verified.

- **Collect read-only Entra observations** uses an administrator-configured, current-workspace connector. Collection requests security-default settings, Conditional Access policies and sign-in observations from Microsoft Graph. Read failures, missing permissions and missing observations remain explicit gaps.

- **Evaluate read-only AD snapshot** accepts JSON from the supplied Windows/RSAT collector. It evaluates effective password policies, selected enabled-account flags and optional sampled security-event observations. Uploaded snapshots are not authenticated solely by a SHA-256 hash. Verify the collector origin, scope, capture time and actual source before relying on them.

A configuration check demonstrates only its stated setting. For example, an enabled MFA policy does not prove every account and application is protected. A sign-in observation is a bounded historical sample, not a live credential challenge or a penetration test. The screen reports each check's implementation/effectiveness dimension, criteria, observed counts and limitations. No check automatically marks an entire standard provision compliant.

Evidence is encrypted with the installation's existing evidence encryption provider and tenant-bound context. Downloads require an authenticated current-workspace session and are attachments; uploaded HTML is not executed. Artifact hashes and protected-payload integrity are retained. Raw Graph observations and submitted evidence are not sent to the risk AI by this audit workflow.

3. Test and review every safeguard

Find a reference using matrix search and the **Untested / unresolved** or **Failed effectiveness** filter. Previous and Next page through the complete matrix without discarding items.

Choose **Record safeguard test / review**. Record all three dimensions independently:

Dimension	Available conclusions	Meaning
Applicability	applicable, not applicable, undetermined	Whether the exact provision applies to the documented scope.
Implementation	implemented, partial, not implemented, unknown, not applicable	Whether the required safeguard has been put in place.
Effectiveness	passed, failed, not tested, insufficient evidence, not applicable	Outcome of the actual scoped operating test or reviewed evidence.

Enter a meaningful applicability/conclusion rationale, actual procedure and scope, and observed results. Select supporting evidence and exact technical checks. For operator-submitted files or AD snapshots, verify source provenance and record how it was checked. A hash establishes content identity, not the truth of the observation.

A tested pass requires an applicable and implemented safeguard with recorded evidence. Configuration-only checks cannot be used as a technical effectiveness pass. Technical passes require an effectiveness observation, and all selected checks must pass; failed or insufficient checks cannot silently be overridden as a technical pass. Current technical evidence must be no older than 30 days when reviewed. Manual evidence review records the human reviewer and their procedure and observations; it is not described as an independent machine measurement. Not-applicable exclusions also require supporting evidence and provenance verification.

Draft reviews may remain undetermined or not tested. Saving such a review increases the reviewed count but does not increase the passed count. Record failures and gaps honestly; do not invent observations to complete a matrix.

4. Independent final review

A tenant administrator, platform administrator or auditor other than the audit creator must finalize the audit. Risk managers may create and test audits but cannot perform final approval. The reviewer must:

1. Compare every framework catalogue against its complete source edition.

2. Select recorded completeness evidence and write the completeness review statement.

3. Resolve every safeguard's applicability and every applicable safeguard's implementation and tested effectiveness.

4. Confirm the catalogue has not changed since the snapshot.

5. Choose **Finalize reviewed audit**.

Unresolved or untested applicable safeguards block finalization. A completed audit may contain failed tests and implementation findings; completion does not mean compliance. A scope with only supported not-applicable exclusions is reported as having no applicable safeguards, rather than as proven effective controls.

Finalization requires the existing audit-signing configuration. It binds the full scope, source catalogue, reviewers, decisions and protected-evidence identities to a signed audit event. The finalized snapshot becomes read-only. Changes to source records are reported without rewriting historical conclusions. A mismatch in the stored snapshot, encrypted evidence or signed history marks the conclusion unverified and must be investigated. Do not treat snapshot integrity verification as proof that the underlying control is effective.

5. Reports and provenance

Use **Export JSON**, **Export PDF** or **Export CSV** from the audit. Reports retain scope, framework editions, every source reference, the three dimensions, actual procedures and observations, reviewer attribution and evidence references. JSON includes check observations and metadata; PDF includes the full safeguard/review narrative and summary; CSV provides one row per safeguard with the review dimensions and evidence references. Raw protected artifacts are downloaded separately through authenticated evidence downloads.

An open audit exports as incomplete. Untested and insufficient-evidence outcomes are preserved, not converted to passes. Finalized reports include the reviewer, finalization time, snapshot digest, integrity status and scoped conclusion. The software does not claim certification, exhaustive external-standard mapping or live system coverage that was not observed.

API reference

All routes are authenticated and tenant-scoped. Substitute actual IDs.

- `POST /api/compliance/audits`: title, scope, framework_ids, include_unmapped_controls.

- `GET /api/compliance/audits?limit=100&offset=0`: saved audits, with total and pages.

- `GET /api/compliance/audits/{id}`: complete snapshot, counts, source-change status, evidence metadata and all safeguard items.

- `POST /api/compliance/audits/{id}/evidence-files`: multipart file upload.

- `GET /api/compliance/audits/{id}/evidence/{evidence_id}/download`: authenticated protected-artifact download.

- `POST /api/compliance/audits/{id}/collect-entra`: connector_id.

- `POST /api/compliance/audits/{id}/active-directory-snapshots`: snapshot plus organization-selected password/lockout thresholds.

- `PUT /api/compliance/audits/{id}/items/{item_id}/review`: current item version, separate dimension states, method, reason, procedure, observations, evidence_ids, check_refs and provenance review.

- `POST /api/compliance/audits/{id}/finalize`: current audit version, catalogue_complete_attested, completeness_statement and completeness_evidence_ids.

- `GET /api/compliance/audits/{id}/export/json`, `/pdf` or `/csv`.

- `POST /api/compliance/connectors/entra`: administrator-only encrypted connector configuration.

- `GET /api/compliance/connectors`: connector metadata for audit operators; secrets are not returned.

- `POST /api/compliance/connectors/{id}/disable`: administrator-only collection disablement; prior audit evidence is preserved.

- `GET /api/compliance/collectors/active-directory.ps1`: read-only collector download.

The exact request schemas are available in the installation's `/docs` interface. Stale versions and finalized-audit writes return conflicts. Cross-workspace audit, item, connector and evidence IDs are not accepted. Existing risk assessment and Requirements APIs remain available.

Control-owner independence

For conclusive reviews and finalization, an identified control owner (user ID/email) cannot attest their own control. Owners may save an unresolved draft. Current control versions are locked and compared with the snapshot before a conclusive decision. Changed controls require a fresh snapshot. Existing finalized snapshots are preserved. Free-text group names are not a directory identity; this check does not replace organization-specific independence governance or fine-grained permissions.

Risk change history and independent remediation closure

Author: Shahryar Jahangir, Aniza Inc. Version 5.54.14.

View risk changes

Open **Risks**, choose **Manage**, then **Change history**. The history shows recorded creation, edits (including applied AI score changes) and resolution/closure. Expand a record to compare the available before and after fields. Refresh returns to the newest events. Previous and Next navigate in pages of 50. Back to risk retrieves the current record without triggering a new AI assessment.

The signed status is per event. **Verified** means the recorded event matches its configured audit HMAC. **Unsigned** means no signature was stored. **Not verified** means the historical signature cannot currently be checked. **Invalid** means the signature or stored payload is invalid; snapshot content is withheld. An individual valid signature does not prove the entire history is complete. Missing historical fields are never reconstructed. PostgreSQL append-only privileges and external audit anchoring are separate deployment controls; SQLite history is not WORM storage.

API: `GET /api/risks/{risk_id}/history?limit=50&offset=0`. The API accepts 1-200 events per page. It uses the same selected-tenant risk-read access as the risk report. An inaccessible risk returns 404. This is a read-only view of existing committed audit records.

Close a remediation with an independent review

1. Create the finding and remediation. Assign its accountable owner.

2. Record corrective work and move the remediation to **ready_for_review**.

3. An independent authorized tester records a passing test on the finding's control after that readiness submission. The tester must not be the remediation creator or a recorded lifecycle participant.

4. Upload the retest's supporting files on the same control after readiness. File uploads use the existing evidence encryption provider. A URL/hash-only evidence registration does not satisfy the file requirement.

5. A tenant administrator or auditor who did not create or participate in the remediation opens **Remediations -> Transition**, chooses **closed**, selects the passing retest and 1-5 supporting files, and explains how those files support the result in the review note. Platform administrators still operate within their selected tenant.

6. The server checks the reviewer and tester identities, current readiness/version, control and tenant ownership, test result, timestamps, file availability, authenticated decryption and content hashes before committing. The closure audit record retains the exact retest, file hashes, reviewer, readiness timestamp and attestation.

The creator, any recorded non-closure lifecycle participant, and a named owner matching the current user's ID/email cannot close the remediation. Ownership is currently free text: use the actual email to identify a person; arbitrary group/display labels are not a directory identity. Unsigned legacy audit history uses its recorded actor IDs under existing access protections. Historical signed audit events must verify with the configured signing key; changing/removing that key blocks new closure until the original history can be verified. Missing current readiness/creation history blocks closure. Do not rewrite historical audit records to bypass this check. If legacy creation/readiness provenance is unavailable, investigate and create a new finding-linked remediation with complete provenance rather than fabricating old events. The old record remains preserved.

A failed, stale, unrelated or unavailable test/file cannot satisfy closure. A new readiness submission requires a subsequent retest and subsequent evidence uploads. Previously closed remediations are preserved. Reopening follows the existing lifecycle, with no automatic rewriting of previous closure decisions.

A human-entered passing result and uploaded file are reviewed observations. They do not prove that LexiGrid independently executed a technical test or establish compliance with an entire standard. The reviewer must examine the evidence and record an accurate conclusion.

API: `GET /api/remediations/{id}/closure-context` lists eligible tests/files for the finding's control. Existing `POST /api/remediations/{id}/transition` requests for `closed` must include `retest_id`, `evidence_ids`, `version`, `state` and `note`. Other transitions retain their existing request fields. These checks require no database migration, key replacement, or customer record conversion.

Risk acceptance, expiry and independent approvals

Author: Shahryar Jahangir, Aniza Inc. LexiGrid.

Request bounded risk acceptance

Create the risk as open or mitigating. In **Risks -> Manage -> Acceptance & expiry**, examine the current title, description, owner, category, score and version. Enter a substantive business rationale and an expiry in your local time. The browser converts it to an absolute UTC instant before submission. There is no default perpetual acceptance. One pending request is allowed per risk; reject an obsolete pending request before replacing it. A renewal can be requested while the previous acceptance is still current.

The request stores the exact risk fields and version, rationale, requester and expiry, bound to its committed audit event. It does not silently change the official score or status. Links to other controls, policies, evidence and assessments are not part of this core risk snapshot: review those separately and revise the risk when circumstances change.

Independently decide or revoke

Open **Risk Acceptance** for paginated pending decisions, recorded approvals, historical requests or re-review events. Open a risk and expand **Exact risk snapshot reviewed** before deciding. An authorized tenant administrator, risk manager or auditor may approve only when they are not the requester, a recorded risk author, or an identified accountable owner. Routing a request through another person does not remove the author restriction. Owners are identified by exact user ID/email and explicit owner-role stakeholders. Group names/free-text labels are not directory identities. Unknown historical authorship cannot be reconstructed automatically.

Choose **Approve exact risk until expiry** or **Reject request**, enter the independent review rationale, then confirm. Approval rechecks content, version, provenance, identity and expiry inside the transaction. A stale or already decided request cannot be approved. Approval sets status to accepted and increments the risk version without changing likelihood or impact. Requests, decisions and earlier superseded acceptances remain in history.

Revoke acceptance records a reason and returns the still-bound accepted risk to mitigating. A new approval supersedes prior approvals and resolves pending expiry review events for that risk. New acceptance requires a fresh independent decision; a recorded generic risk approval does not constitute acceptance.

Expiry and re-review

A dedicated API-process worker scans once per minute, independently of whether SMTP is configured or enabled. It starts with the API and resumes scanning after restart; multiple processes serialize changes through the risk row and current acceptance state. Linux PostgreSQL concurrency tests verify one expiry and one durable review event across independent worker transactions. There is no exactly-once email delivery claim.

At expiry, a still-bound accepted risk moves to mitigating, its version increments, and the same transaction records an expiry audit event and durable re-review item. Its score is retained. The worker queues existing opted-in risk notifications where configured; actual SMTP delivery depends on the existing notification service. Expired approval is ineffective immediately in the acceptance view even if the next scan has not yet run. Risk list status may await that scan. Old approvals for changed, closed or newly accepted risks are superseded rather than reopening those risks.

Use **Risk Acceptance -> Re-review required** to locate the follow-up. Reassess the risk and request fresh independent approval or continue mitigation. Successful new approval resolves the durable review item while preserving its audit trail. Records with invalid provenance fail closed and require administrator investigation. A tenant scan failure is logged with tenant ID and safe exception type; it does not stop scans of other tenants. A damaged record may block expiry processing for its tenant until investigated.

Operational setting: `LEXIGRID_ACCEPTANCE_WORKER=1` is the default. Explicitly setting it to 0 disables the automatic scan and requires a separately managed scanner. Run `.venv/bin/python -c 'from app.risk_acceptance import scan_all; print(scan_all())'` only with the installation's existing runtime environment securely loaded, including its original database and signing configuration. Do not copy credentials into command-line arguments. The API acceptance view still evaluates expiry when the worker is stopped. Observe structured `risk.acceptance.*` events and investigate scan failures; application health alone does not prove the worker has completed a scan.

Edit, close and AI assessment

Creating a risk as accepted or setting an ordinary edited risk to accepted is rejected. To change accepted content or apply a new AI rating, first set the risk to open or mitigating, then make the change and request fresh acceptance. An unchanged save of an accepted risk preserves its version. Risk closure retains its separate resolution workflow and does not imply acceptance. Existing accepted risks are preserved; without current bound approval they display a review warning. No historical approval or missing fields are fabricated.

Native approvals and generic workflows

The **Approvals** workspace binds new risk, policy and finding requests to their exact tenant-owned content. **Binding status** distinguishes current, stale, legacy unbound and unverifiable records. Recorded approval and effective current approval are separate. Risk reports retain historical decisions while refusing to present stale approvals as the current approving actor.

Requesters, recorded content creators/editors and identified owners cannot approve via a different requester. Stale native approval requests must be rejected and recreated. A new policy publication requires both the unchanged reviewed policy version and matching request/decision audit provenance. Existing published policies are preserved; older unbound decisions cannot authorize a new publication.

Generic multi-step enterprise workflows also reject assigned creators, editors and identified owners; the initiator remains excluded. Approval rechecks the bound version/digest before deciding a step, and the governed transition rechecks it before consumption. Rejection remains available to close an obsolete pending run. No normal author override is provided. The current tenant-wide roles and free-text owner labels do not implement business-unit/object-level permissions or reconstruct unknown legacy authorship.

Audit control-owner independence

An identified control owner cannot issue a conclusive passed/failed or not-applicable safeguard review, nor finalize an audit containing their control. They may record an unresolved draft. A different audit creator/final reviewer remains required. Control identities are checked against the snapshot and current locked control versions; a changed control requires a fresh catalogue snapshot. This preserves existing finalized snapshots and their signed integrity. Ownership matching uses recorded user ID/email; arbitrary group/display labels require organizational identity governance outside this check. No automated independence exception is granted.

API

- `GET/POST /api/risks/{id}/acceptances` reads history or requests acceptance with risk_version, reason and timezone-aware expires_at.

- `POST /api/risks/{id}/acceptances/{acceptance_id}/decision` accepts version, decision (approved/rejected/revoked) and note.

- `GET /api/risk-acceptances?state=pending&limit=50&offset=0` lists tenant-scoped acceptance records.

- `GET /api/risk-acceptance-reviews?limit=50&offset=0` lists unresolved expiry reviews.

- Pagination supports 1-200 records per request; offset pagination does not impose a total record ceiling.

Records reuse existing tenant-isolated tables and append-only audit controls. There is no schema migration, key replacement, destructive conversion or automatic modification of legacy accepted risks. Signing provenance is verified when configured; unsigned history is not WORM proof. Invalid signed requests and altered approval payloads cannot be relied on. Product checks do not establish certification or prove that a human-entered observation is true.